
附 件

“皖政通”
服务安全保障规范

2022 年 03 月

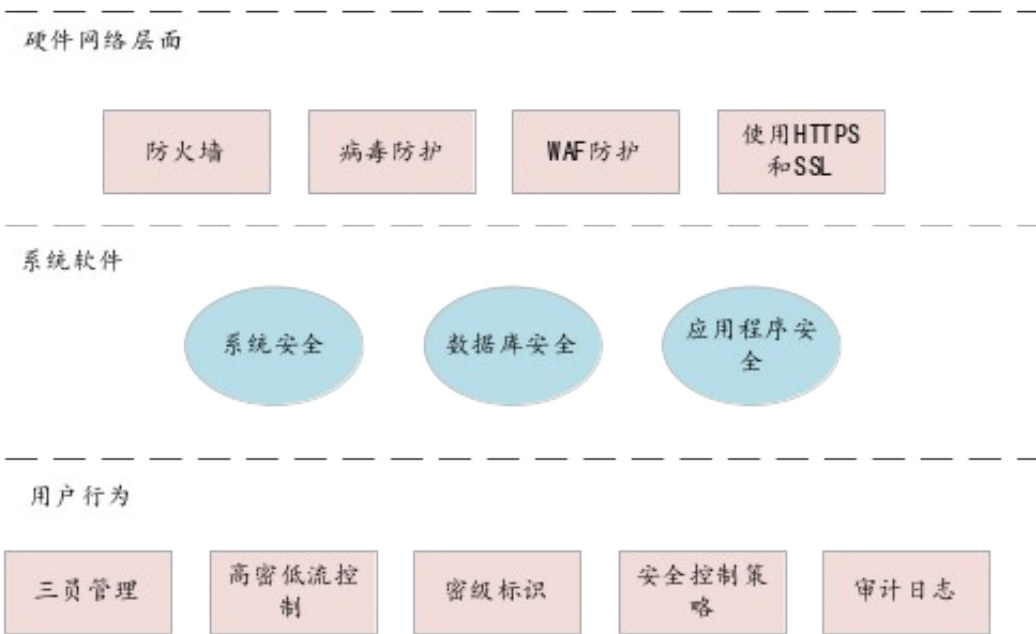
目 录

1. 安全性设计.....	3
2. 网络安全.....	3
1.1 防火墙.....	3
1.2 病毒防护.....	4
1.3 WAF 防护.....	4
1.4 使用 HTTPS 和 SSL.....	7
3. 系统安全.....	11
4. 数据库安全.....	12
1.1 数据库权限控制.....	12
1.2 数据库备份还原机制.....	12
1.3 数据加密机制.....	12
5. 应用程序安全.....	12
1.1 WEB 漏洞屏蔽.....	12
1.2 安全账户认证.....	14
1.3 访问控制.....	15
1.4 安全审计.....	17
1.5 应用程序安全措施.....	19
1.5.1 页面权限.....	19
1.5.2 表单数据项保存权限.....	19
1.5.3 工具类的使用限制.....	19
1.5.4 上传下载文件.....	20
1.5.5 自定义错误.....	20
1.5.6 后台数据校验.....	20
1.5.7 交互数据加密.....	20
1.5.8 敏感数据加密.....	20
1.5.9 安全设计任务列表.....	21
1.5.10 页面统一权限认证过滤器.....	25

1.5.11 禁止 SQL 注入.....	26
1.5.12 禁止 XSS.....	26
1.5.13 禁止 CSRF.....	26
1.5.14 操作审计日志.....	26
1.5.15 表单数据统一授权模式.....	27
1.5.16 附件加密.....	28
1.5.17 关键字段加密.....	28
1.5.18 页面和 Cookie 中不出现用户及敏感信息.....	29
6. 安全管理制度.....	29
1.1 安全控制策略.....	29
1.1.1 超期强制修改密码.....	29
1.1.2 初次使用强制修改密码.....	30
1.1.3 使用强口令.....	30
1.1.4 密码输入错误失败锁定.....	30
1.2 审计日志.....	30
1.2.1 普通人员日志.....	30
1.2.2 系统管理员日志.....	32
1.2.3 安全保密员日志.....	32

1. 安全性设计

安全系统贯穿于系统平台应用的全部过程，它是信息安全得以保障的关键所在。安全机制主要是通过网络安全、系统安全、数据库安全、应用程序安全、管理制度安全等几个方面的设计来实现，这些安全角度覆盖了硬件网络、系统软件、用户行为。



2. 网络安全

2.1 防火墙

防火墙是实现网络安全最基本、最经济、最有效的的安全措施之一。通过制定严格的安全策略实现内外网络或内部网络不同信任域之间的隔离与访问控制。并且可以实现单向或双向控制，对一些高层协议实现较细粒的访问控制。

对于应用服务器关闭除 HTTP、SSL、数据库外所有的端口。

对于数据库服务器启用白名单模式，只有允许的主机才允许访问。

其他必须的防火墙规则。

2.2 病毒防护

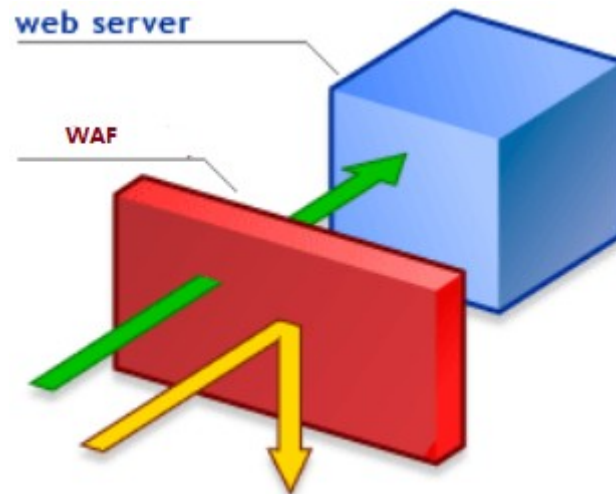
在网络环境下，计算机病毒有不可估量的威胁性和破坏力。一般使用的 Windows 操作系统，比较容易感染病毒，安装一套病毒防护软件可以有效的降低计算机受病毒感染的风险程度，结合防火墙使得系统得到进一步安全保障。

2.3 WAF 防护

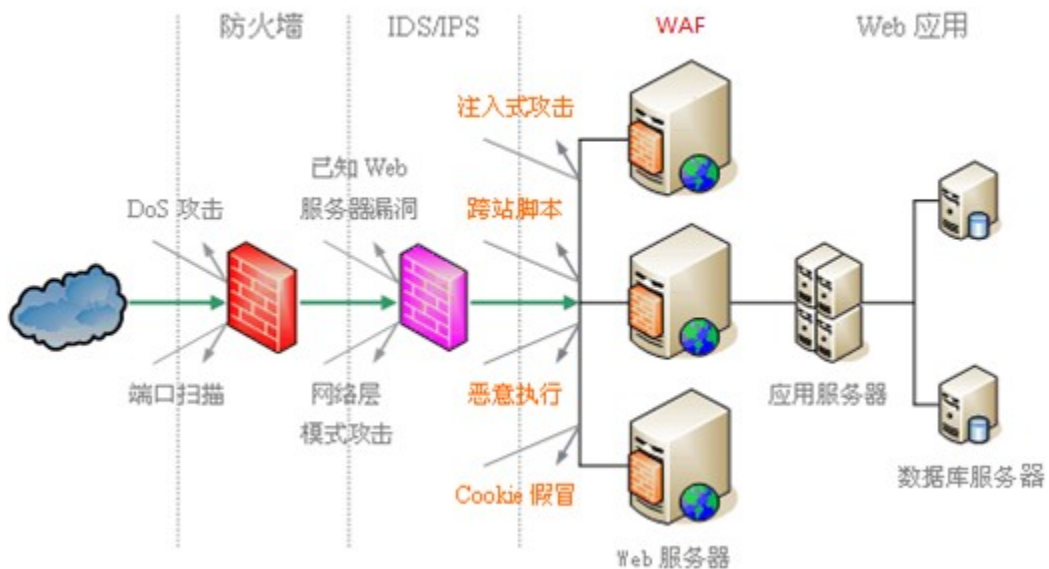
Web 应用防护系统（也称：网站应用级入侵防御系统。英文：Web Application Firewall，简称：WAF）。利用国际上公认的一种说法：Web 应用防火墙是通过执行一系列针对 HTTP/HTTPS 的安全策略来专门为 Web 应用提供保护的一款产品。WAF 这一防御系统能够保护各网站 Web 服务器免受应用级入侵，它弥补了防火墙、IPS 这类安全设备对 Web 应用攻击防护能力不足的问题。

WAF 具有以下特点：

- 请求过滤：当请求提交时，在对提交的数据被 web 服务器或其他程序使用之前进行分析。
- 避免逃避技术：在对数据进行分析之前将路径和参数一般化，以避免遗漏。
- 理解 HTTP 协议：由于引擎能够理解 HTTP 协议，故能进行特殊的细粒度的检查
- POST 数据分析：引擎将截取采用 POST 方式传递的数据
- 审计纪录：能够详细记录每一组请求的内容（包括 POST 的内容）以备日后详细分析
- HTTPS 过滤：由于引擎内嵌入服务器，所以可以访问解密后的请求数据其防护的概念如下图所示：



图：WAF 防护的概念



图：WAF 入侵侦测与防护引擎安装位置示意图

WAF 的运作设计有以下的基础概念：

- 让使用者可以做任何想做的事情 (Empower users to do what they want)
- 使用者设定的动作才会执行 (Don' t do anything implicitly)
- 预设是不做任何动作 (Be passive)

WAF 的部署架构：

- 与 Web Server 结合 。
- 与 Apache 或 Nginx 结合部署为网关，当作一个反向代理。

WAF 功能特点:

1. HTTP 流量记录:

Web 服务器已有的日志功能已经足够进行访问请求分析，但是就 Web 的应用分析还有些不足，特别是大多情况下没办法记录下请求体。WAF 充分的获取了 HTTP 交互中的所有内容，并记录完整的请求和响应。其日志功能可以允许更细致的做出判断，并确保相关的数据都被记录下来。一些请求和响应中的某些关键字段可能包含敏感数据，WAF 可以被配置成在记录这些审计日志前隐藏它。

2. 实时监控和攻击检测

除了提供记录日志功能外，WAF 还能实时的监控 HTTP 的流量以检测攻击。在某些时候，WAF 做为一个 WEB 入侵检测工具，可以对发生在 WEB 系统上的一些可疑事件做出响应。

3. 攻击防御和及时修补

WAF 能够立即针对 WEB 应用系统进行攻击防御，有三种通用的方法：

(1) 消极(negative)安全模型：消极安全模型监控那些异常的、不常用的和通用的 WEB 攻击类请求。它统计每个请求的有关 IP 地址、应该连接、和用户帐户的异常记录，当出现较高的异常记录时，会记录日志并完全的阻止访问。

(2) 积极安全模型：部署积极安全模型后，只有那些明确的请求被允许通过，其它的一律禁止。这个模式要求对需要保护的 WEB 应用要非常的了解。因此积极安全模式最好是用于那种大量访问却很少更新的系统，这样才能使这种模型的维护工作量降到最低。

(3) 已知漏洞攻击：其规则语言使 WAF 成为一个理想的外部修补工具，外部修补（有时是指虚拟修补）可以减少机会之窗。一些组织修补这些应用的漏洞通常需要几周的时间，使用 WAF，应用系统可以从外部修补，可以保证系统安全直到有一个合适的补丁来应用到系统中。

4. 灵活的规则引擎

WAF 规则语言被设计的简单易用，通用的操作是简单的，而复杂的操作也是可以实现的。经过认证的 WAF 规则，放在 WAF 中，包含了一整套规则，它实现了通用目的强化、协议正规化和对一些通用 web 应用安全问题的检测。

5. 嵌入式模式部署

WAF 是一个可嵌入式的 WEB 应用防火墙，**意思**就是它可以做为以 Apache 或 Nginx 为基础的已经提供 WEB 服务的 WEB 服务器的一部分。这样的部署有一些特殊的优势：

(1) 不改变已有的网络结构。只需要花几分钟就可以为你的 WEB 服务器添加 WAF，而且由于它默认被设计为完全的被动方式，你可以自由的逐步部署并且只使用你需要的特性。同样也可以根据你的需要轻松的删除或停用它。

(2) 不存在单点故障。与网络设备部署方式不同，你不会给你的系统带来新的故障点。

(3) 绝对支持负载均衡。因为它以嵌入方式运行在 WEB 服务器上，WAF 会自动的利用附加的负载均衡特性。你不需要考虑负载均衡，除非你的系统本来就需要它。

(4) 极少开销。因为它在 WEB 服务器进程内工作，不会带来网络间接通信的负载，而且只进行最小的分析和数据交换开销。

(5) 加密或压缩内容没问题。许多 IDS 系统分析 SSL 流量的时候很困难，但对于 WAF 没有麻烦，因为它工作于已解密和解压的数据环节。

6. 基于网络的部署

在基于 apache 或 Nginx 的反向代理模式上 WAF 同样能工作的很好，我们很多客户选择这样做。在这种情形下，装了 WAF 的可以保护任一种 WEB 服务器（即使它不是 apache 或 Nginx 的）。

2.4 使用 HTTPS 和 SSL

SSL (Secure Sockets Layer 安全套接层)，及其继任者传输层安全 (Transport Layer Security, TLS) 是为网络通信提供安全及数据完整性的一种安全协议。TLS 与 SSL 在传输层对网络连接进行加密。用以保障在 Internet 上数据传输的安全，利用数据加密 (Encryption) 技术，可确保数据在网络上之传输过程中不会被截取及窃听。

当前版本为 3.0。它已被广泛地用于 Web 浏览器与服务器之间的身份认证和加密数据传输。

SSL 协议位于 TCP/IP 协议与各种应用层协议之间，是一种国际标准的加密及身份认证通信协议，为 TCP 提供一个可靠的端到端的安全服务，为两个通讯个体之间提供保密性和完整性（身份鉴别）。SSL 协议可分为两层：SSL 记录协议（SSL Record Protocol）：它建立在可靠的传输协议（如 TCP）之上，为高层协议提供数据封装、压缩、加密等基本功能的支持。SSL 握手协议（SSL Handshake Protocol）：它建立在 SSL 记录协议之上，用于在实际的数据传输开始前，通讯双方进行身份认证、协商加密算法、交换加密密钥等。

SSL 协议特点

1. SSL 协议可用于保护正常运行于 TCP 之上的任何应用协议，如 HTTP、FTP、SMTP 或 Telnet 的通信，最常见的是用 SSL 来保护 HTTP 的通信。
2. SSL 协议的优点在于它是与应用层协议无关的。高层的应用协议（如 HTTP、FTP、Telnet 等）能透明地建立于 SSL 协议之上。
3. SSL 协议在应用层协议之前就已经完成加密算法、通信密钥的协商以及服务器的认证工作。在此之后应用层协议所传送的数据都会被加密，从而保证通信的安全性。
4. SSL 协议使用通信双方的客户证书以及 CA 根证书，允许客户/服务器应用以一种不能被偷听的方式通信，在通信双方间建立起了一条安全的、可信任的通信通道。
5. 该协议使用密钥对传送数据加密，许多网站都是通过这种协议从客户端接收信用卡编号等保密信息。常用于交易过程中。

SSL 功能

1. 客户对服务器的身份认证：SSL 服务器允许客户的浏览器使用标准的公钥加密技术和一些可靠的认证中心（CA）的证书，来确认服务器的合法性。
2. 服务器对客户的身分认证：也可通过公钥技术和证书进行认证，也可通过用户名，password 来认证。
3. 建立服务器与客户之间安全的数据通道：SSL 要求客户与服务器之间的所有发送的数据都被发送端加密、接收端解密，同时还检查数据的完整性。

SSL 协议工作的基本流程

1. 接通阶段：客户机通过网络向服务器打招呼，服务器回应
2. 密码交换阶段：客户机与服务器之间交换双方认可的密码，一般选用 RSA 密码算法
3. 会谈密码阶段：客户机器与服务器间产生彼此交谈的会谈密码
4. 检验阶段：客户机检验服务器取得的密码
5. 客户认证阶段：服务器验证客户机的可信度
6. 结束阶段：客户机与服务器之间相互交换结束的信息

HTTPS（全称：Hypertext Transfer Protocol over Secure Socket Layer），是以安全为目标的 HTTP 通道，简单讲是 HTTP 的安全版。即 HTTP 下加入 SSL 层，HTTPS 的安全基础是 SSL，因此加密的详细内容就需要 SSL。它是一个 URI scheme（抽象标识符体系），句法类同 http: 体系。用于安全的 HTTP 数据传输。https:URL 表明它使用了 HTTPS，但 HTTPS 存在不同于 HTTP 的默认端口及一个加密/身份验证层（在 HTTP 与 TCP 之间）。这个系统的最初研发由网景公司进行，提供了身份验证与加密通讯方法，现在它被广泛用于万维网上安全敏感的通讯，例如交易支付方面。

HTTPS 和 HTTP 的区别

1. https 协议需要到 ca 申请证书。
2. http 是超文本传输协议，信息是明文传输，https 则是具有安全性的 ssl 加密传输协议。
3. http 和 https 使用的是完全不同的连接方式，用的端口也不一样，前者是 80，后者是 443。
4. http 的连接很简单，是无状态的；HTTPS 协议是由 SSL+HTTP 协议构建的可进行加密传输、身份认证的网络协议，比 http 协议安全。

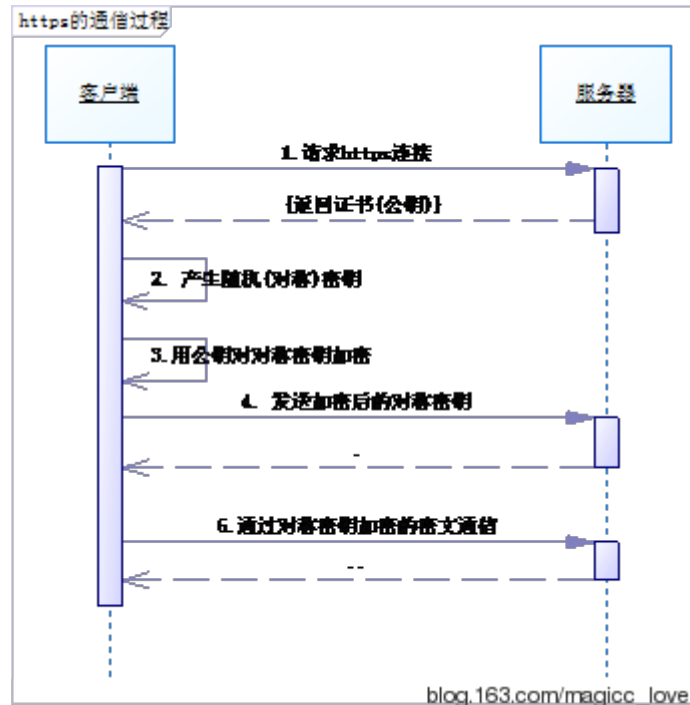
HTTPS 的实现原理

有两种基本的加解密算法类型

1. 对称加密：密钥只有一个，加密解密为同一个密码，且加解密速度快，典型的对称加密算法有 DES、AES 等；
2. 非对称加密：密钥成对出现（且根据公钥无法推知私钥，根据私钥也无法推知公钥），加密解密使用不同密钥（公钥加密需要私钥解密，私钥

加密需要公钥解密），相对对称加密速度较慢，典型的非对称加密算法有 RSA、DSA 等。

HTTPS 的通信过程



HTTPS 通信的优点

1. 客户端产生的密钥只有客户端和服务端能得到；
2. 加密的数据只有客户端和服务端才能得到明文；
3. 客户端到服务端的通信是安全的。

HTTPS 解决的问题

一、信任主机的问题.

采用 https 的服务器必须从 CA (Certificate Authority) 申请一个用于证明服务器用途类型的证书。该证书只有用于对应的服务器的时候，客户端才信任此主机。所以目前所有的银行系统网站，关键部分应用都是 https 的。客户通过信任该证书，从而信任了该主机。其实这样做效率很低，但是银行更侧重安全。这一点对我们没有任何意义，我们的服务器，采用的证书不管是自己发布的还是从公众的地方发布的，其客户端都是自己人，所以我们也就肯定信任该服务器。

二、通讯过程中的数据的泄密和被篡改

1. 一般意义上的 https，就是服务器有一个证书。

- a) 主要目的是保证服务器就是他声称的服务器，这个跟第一点一样。
- b) 服务端和客户端之间的所有通讯，都是加密的。具体讲，是客户端产生一个对称的密钥，通过服务器的证书来交换密钥，即一般意义上的握手过程。接下来所有的信息往来就都是加密的。第三方即使截获，没有任何意义，因为他没有密钥，当然篡改也就没有什么意义了。

2. 少许对客户端有要求的情况下，会要求客户端也必须有一个证书。

- a) 这里客户端证书，其实就类似表示个人信息的时候，除了用户名/密码，还有一个 CA 认证过的身份。因为个人证书一般来说是别人无法模拟的，所有这样能够更深的确认自己的身份。
- b) 目前少数个人银行的专业版是这种做法，具体证书可能是拿 U 盘（即 U 盾）作为一个备份的载体

3. 系统安全

系统层安全风险安全指的是信息系统运行平台的安全风险，包括操作系统、系统软件等。目前的操作系统或系统软件无论是 Windows 还是 Unix 系统以及其它厂商开发的系统软件（如 Apache），本身都存在安全漏洞，如果没有进行合理的安全配置，如修补安全漏洞，关闭一些不常用的服务端口等，那么入侵者就有可能利用这些漏洞侵入系统。

对服务器部署如下安全策略，以提高系统的安全性：

- 关闭一些不常用的却存在安全隐患的应用。
- 增加管理员帐号的复杂程度，限制不必要的账户权限。
- 及时更新系统补丁。
- 关闭不用的端口、服务及共享。
- 定时对应用程序的静态资源进行脚本校验，确认数据未经篡改。

4. 数据库安全

一.1 数据库权限控制

通过系统权限、数据权限、角色权限管理建立数据库系统的权限控制机制，通过安全审计记录和跟踪用户对数据库的操作，防止否认对数据库的安全责任。

一.2 数据库备份还原机制

建立数据恢复和容错处理机制，当系统数据出现问题的时候，把对数据的破坏减低到最小，并能够对损坏的数据进行恢复。通过磁盘阵列对数据库提供容错保障。对数据库部署周期性的备份策略，方便数据的回溯和还原。

一.3 数据加密机制

对敏感字段进行加密处理，即使拥有数据库管理权限也无法获取原文信息，有效保护了用户的私密信息。

5. 应用程序安全

一.1 Web 漏洞屏蔽

目前梦创公司所提供的 http 模型框架可以有效的屏蔽以下 web 漏洞：

- 未验证输入：几乎所有的 web 应用都需要处理各种各样的来自不可信任源的输入。它是程序的一个潜在弱点，处理不当可能引发很多恶果。比如，通过 http 请求从浏览器向 web 应用发送参数，攻击者可以任意修改请求，从而造成破坏。

- 不完善的访问控制：很多站点的访问控制策略过于复杂或者设置、实现不当。攻击者可以看到自己本不应当看到的内容，并且提高自己的权限。
- 不完善的认证和会话管理：会话令牌和用户信任状，比如密码、钥匙和会话 cookies 需要得到保护，否则认证机制形同虚设。在更改密码、获取遗忘的密码和更新帐户信息的过程中，信任状和令牌未能正确的处理，认证系统就存在很大的被攻击危险。会话令牌需要在会话的整个周期内受到保护，SSL 可以确保这点。
- SQL 注入式攻击：web 应用可能使用许多外部系统，比如系统调用、SQL database 和模版系统。web 应用使用这些程序时往往要传入参数。恶意代码可以通过参数传给解释程序，然后被执行。本系统所有 SQL 变量都使用参数模式，防止 SQL 注入。
- 跨站点脚本攻击：浏览器执行来自站点的代码，比如 javascript、flash 等。攻击者将可执行的恶意代码脚本作为输入的一部分传给网站的 web 应用，这些脚本然后在其他用户的浏览器中运行，从而对使用它的其他用户造成损害。造成的结果是盗取会话令牌，攻击机器或者哄骗用户。通过 Filter 对所有 Http 传递参数进行过滤，防止 XSS 注入。
- 数据提交时使用 Token 双重验证方式，防止 CSRF 注入。
- 采用前后台双重检验模式，前台 Javascript 校验只作为提升用户易用性，所有数据都需要后台校验通过后才存入数据库。防止用户通过 Javascript 篡改数据或绕过 Javascript 验证。
- 采用三权分立模式，限制系统管理员的权限。
- 支持使用 HTTPS 连接，防止抓包风险。
- 缓存溢出：Web 应用从用户获得各种各样的输入。如果没有恰当的范围检查，输入在缓冲区溢出，覆盖堆栈，可以用来执行任意代码。比如 c 和 c++ 中，此类错误往往是致命的。
- 错误处理机制：应用程序总是要处理各种各样的错误，比如内存溢出、过多用户、超时、数据库错误、认证错误、访问控制错误，输入错误等。应用程序错误处理机制需要明确地告诉用户出现什么错误，但是不留下

任何可用来攻击服务器的信息。比如，操作系统，数据库的版本和数据库的驱动等信息都可能被别有用心用户搜集查找漏洞，然后攻击。

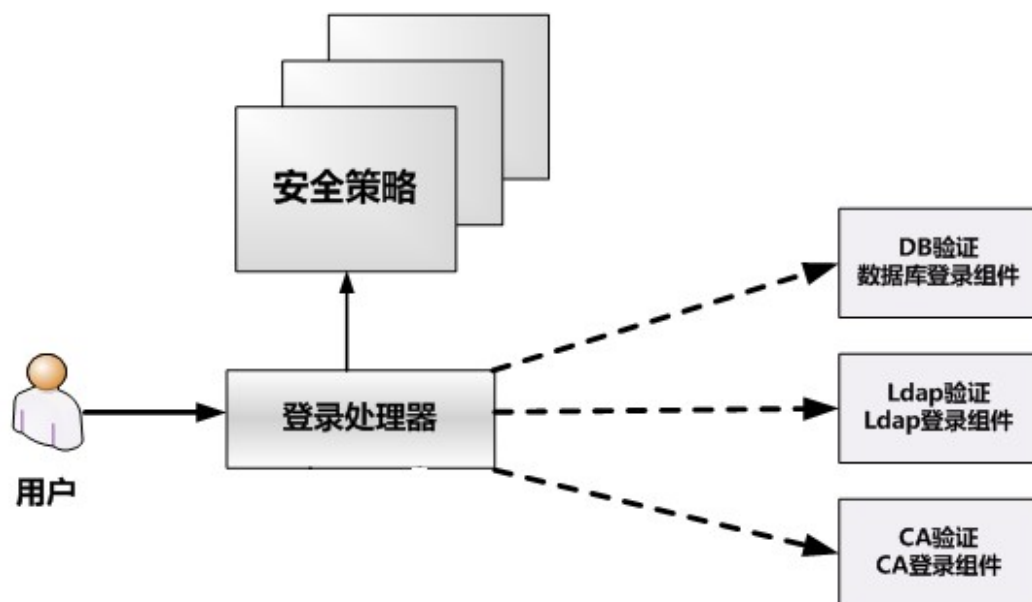
一.2 安全账户认证

一、身份标识符管理

使用证书密钥管理系统，为涉密信息系统全网用户身份和密钥进行统一的集中管理，并且确保用户身份在涉密信息系统中的唯一性。证书密钥管理系统为涉密信息系统提供用户证书申请、颁发、更新、撤销等服务，同时为涉密信息系统中所有应用系统提供用户终端身份信息的管理。

系统提供了多方面用户认证的安全实现。提供多种用户验证方式实现，如：CA 证书验证，数据库验证，LDAP 验证等。并且系统还提供多种安全策略增强登录安全性，如 IP 策略限制用户登录 IP。

用户标识是唯一的，只能将用户禁用，不能删除，以保障用户标识的唯一性。并且用户标识一旦生成不允许通过界面进行修改，保障了用户标识的唯一性和合法性。



图：多种登录认证方式和登录安全策略控制

1、用户验证方式：

- (1) 支持用户名/密码方式验证
- (2) 支持CA证书方式验证登录
- (3) 支持数据库和LDAP验证登录
- (4) 支持CA证书，用户名/密码同时验证

2、安全策略：

- (1) 用户登录IP规则
 - 设置用户可以在哪些IP上登录
 - 设置用户是否限制登录IP
- (2) 帐号策略
 - 强制用户更改密码期限
 - 密码长度最小值
 - 密码复杂度

二、鉴别方式

(1) 重鉴别

用户身份鉴别成功后，当其空闲操作的时间超过规定值(可配置)后，在该用户需要执行其它操作之前，对该用户重新进行身份鉴别。

(2) 鉴别失败

当用户身份鉴别尝试失败次数达到五次后，禁止使用该程序或延长一定时间后再允许尝试，同时形成审计事件并告警。

一.3 访问控制

一、安全保密管理机构

系统配备系统管理员、安全保密管理员和安全审计管理员三类安全保密管理人员，分别负责系统的运行、安全保密和安全审计工作

系统管理员：负责系统的日常运行维护工作

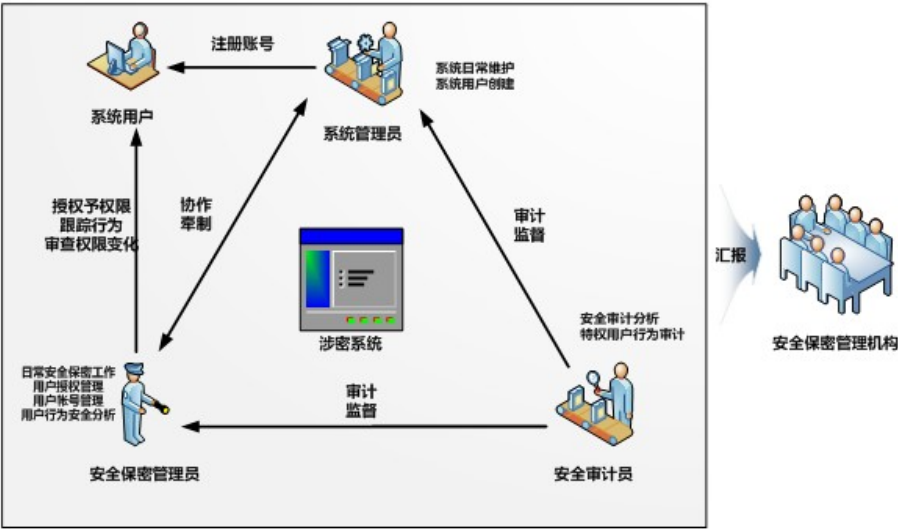
安全保密管理员：负责系统的日常安全保密管理工作，包括用户账号管理以及安全保密和系统所产生的日志的审查分析。

安全审计员：负责对系统管理员、安全保密管理员的操作行为进行审计跟踪分析和监督检查，以及时发现违规行为，并定期向系统安全保密管理机构汇报相关情况。

访问控制通过系统权限控制功能实现。

系统管理员、安全保密管理员、安全审计员（简称“三大员”）的权限设置应相互独立、相互制约，安全保密管理员与安全审计员不得由一人兼任。

1、“三大员”的关系



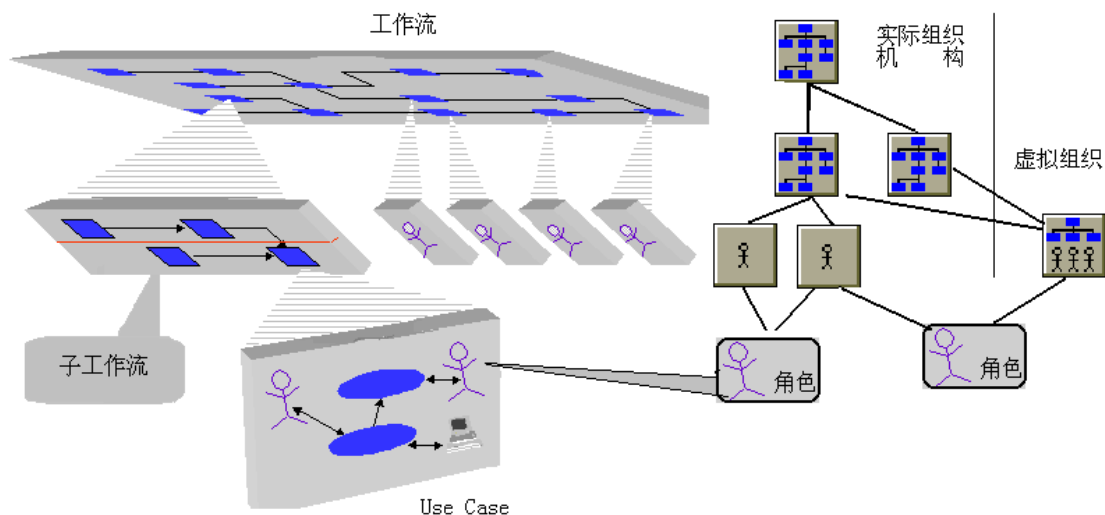
图：“三大员”的关系

二、权限模型

系统基于ORBAC 权限管理模型（Office Role Based Access Control，简称ORBAC）实现一套良好的权限控制框架，为应用软件提供通用的权限解决方案。ORBAC 权限管理模型可以协助系统达到权限管理的完备性和规范性，且在此基础上实现和添加更易使用更强大的扩展功能。

三、总体权限控制解决方案

总体权限控制模型如下图所示：



图：总体权限控制模型

系统中的任何一个活动，都可以描述为在某个业务流程中某个角色(人、部门、虚拟组织如项目组)对系统的一系列交互(Use case)，这样可以对应为三维坐标中的一个点，记为 $A(w_i, u_i, o_i)$ 其中 $w_i \in \text{Workflow}$, $u_i \in \text{Use Case}$, $o_i \in \text{Organization}$, $i \in N$ ，比如文秘的收文登记动作可以描述为：收文登记(收文流程，登记，文秘)。

系统通过提供一个多维的权限控制模型来解决应用软件复杂的权限控制需求，使用权限分配工具通过这些途径就能够完成比较复杂的权限控制。

四、弹性的权限管理体系

系统提供一个弹性的可裁剪的权限管理体系，能够适应不同的管理要求，实施不同的管理策略。多管理纬度，可以按应用，按组织逐级授权，实现分级管理。能够实施简单集中管理到复杂（多级授权等）的权限控制方案。支持按照组织级别（行政级别）逐级授权，分级管理。

五、强大灵活的用户组

系统提供强大灵活的用户组，方便管理员将不同来源的用户分组，可直接对用户组授权。自定义用户组的用户来源，用户可来自特定组织，职级，职务或不同的组合条件。

一.4 安全审计

在应用系统运行当中，用户的业务操作是一个非常重要的环节，用户的不当操作甚至恶意破坏操作会对系统产生很坏的影响。系统提供全方位的操作留痕处理，为用户的正确或者错误操作提供基本的数据纪录，并且为管理员提供功能强大的审查功能。

一、审计范围

(1) 应据对应用系统的脆弱点进行分析，并根据系统运行性能和安全需求确定系统安全审计的范围；

(2) 确定的审计事件范围应对安全事件的事后追查提供足够的信息；

(3) 安全审计应与身份鉴别、访问控制、数据完整性等安全功能的设计紧密结合，并为下述可审计事件产生审计记录：

审计功能的启动和关闭；

系统内用户增加、删除；

用户权限的更改；

系统管理员、系统安全员、审计员和一般操作员所实施的操作；

其它与系统安全有关的事件或专门定义的可审计事件。

二、审计记录内容

(1) 审计记录应提供足够的信息，以确定发生的事件及其来源和结果；

(2) 审计记录应包括以下内容：事件发生的时间、地点、类型、主体和结果(成功或失败)。

(3) 用户访问系统将会进行相应的数据操作，应用平台提供对关键的模块及数据访问的用户和行为记录。并且记录方式可以配置。

三、日志纪录

应用平台提供灵活配置，并且可以有多种输出源（数据库、系统日志、文件）的日志服务。

四、审计记录查询

日志查询按用户需求及权限不同分为简单查询和高级查询两种。

(1) 简单查询：仅提供年、月、日、日志类型等信息的查询。

(2) 高级查询：除提供年、月、日等信息外还可按系统名称、模块名称、

关键字（如用户名、组织名、IP 以及生成的时间段等信息）等进行组合查询。

五、审计记录的保护

对审计信息和审计系统进行特别的授权访问控制，并且审计记录不允许修改，只允许导出不允许导入，保证审计记录不被篡改、伪造和非授权删除。

一.5 应用程序安全措施

一.5.1 页面权限

页面权限的设定主要分为两种：

1. 功能型页面：只给某类特殊人员使用的页面，使用这些页面需要特定的权限。如：用户管理，需要系统管理员权限才可以进行访问。
2. 数据型页面：所有用户都有可能使用到的页面，用户对页面本身没有权限的设定，但是对页面承载的数据有权限的设定。如：各类表单，所有用户都可能使用到，但每个用户只能浏览自己有权限的数据。

对于功能型页面，我们使用人员-权限的授权模式来实现权限的设定，每一个功能型页面都需要指定一个或多个允许访问的权限，进入页面时，将进行人员权限的检查，无权限者禁止访问。也可以将权限设定到目录。

对于数据型页面，我们通过用户访问权限表来解决此问题，用户在文件创建、文件流转中自动获得文件的访问权限，存入用户访问权限表中。当用户需要访问表单及其承载的数据时，将根据用户访问权限表进行判定用户是否拥有访问此数据的权限。

一.5.2 表单数据项保存权限

表单数据项保存必须和修改项权限相结合，只有在表单配置中设置了可保存，才会进行该字段的数据保存操作。防止用户伪造数据，提交不允许修改的数据进行保存。

一.5.3 工具类的使用限制

对于一些对数据进行操作的工具类，必须要在类中进行操作者身份权限的二次确认，防止越权操作数据的情况产生。

一.5.4 上传下载文件

对于下载上传文件的工具类，必须限定其可下载上传的范围，禁止将文件上传到可执行目录；上传文件时禁止由前台指定上传目录；下载文件时禁止由前台指定下载路径；上传时在磁盘上生成的磁盘文件，使用 GUID 来建立文件名，防止用户通过猜测尝试来获取到文件路径；在用户下载文件时，对操作者身份权限进行二次确认，确认该用户有权限下载此文件；禁止用户上传如 jsp 等可执行程序文件。

一.5.5 自定义错误

做好应用程序的自定义错误配置，防止源代码泄露。

一.5.6 后台数据校验

所有的输入数据都必须在后台进行检验，前台 Javascript 校验只作为提升用户易用性。防止用户通过 Javascript 篡改数据或绕过 Javascript 验证。

提供标准的后台校验函数，和目前前台 Js 校验功能一致的后台校验函数，例如：身份证验证、Email 格式验证、手机号验证等。

提供可扩展的后台检验方法，允许开发人员在开发中编写校验方法，方法名固定 Validation，由表单框架在保存前统一调用。若校验不通过则不允许进行保存。此校验方法可返回详细的错误信息。

一.5.7 交互数据加密

在进行数据交互时，若交互的数据是 XML 格式的，需要将数据进行加密，或在接收到 XML 格式数据时进行预处理，防止伪造的 XML 实体造成程序奔溃等问题。

一.5.8 敏感数据加密

对写在配置文件中的敏感数据如：操作系统用户口令、数据库连接串、其他应用程序的接口地址、用户密码等，需要加密进行存放。

一.5.9 安全设计任务列表

序号	国家保密局标准要求	任务及技术实现	备注
一、身份鉴别			
1	用户身份鉴别:应对信息系统中涉及涉密数据应用程序的本地登录、远程登录进行用户身份鉴别。	系统提供以下身份鉴别方式： 1、用户名和密码 2、证书（智能卡或 USB Key） 3、用户名、密码和证书相结合满足和生理特征库相结合的认证方式	应采用生理特征(如指纹、虹膜等)等强身份鉴别方式进行身份鉴别
2	身份标识符:a)用户身份标识符应由系统管理员统一生成，并确保身份标识在此系统生命周期中的唯一性（即某一身份标识符删除后不能再次生成）；b)应对系统内的身份标识符加强管理、维护，确保身份标识符列表不被非授权地访问、修改或删除；c)用	1、通过系统的用户管理生成用户身份的全球唯一标识符 2、系统采用的系统管理员、安全管理员和安全审计员相结合的管理模式实现身份标识符列表不被非授权的访问、修改或删除 3、系统的行为审核对用户的行为进行记录留痕，保证行为	

序号	国家保密局标准要求	任务及技术实现	备注
	户标识符应与安全审计相关联，保证系统内安全事件的可核查性。	记录不能被修改或者删除	
3	口令设置要求： 口令设置应满足如下要求：a) 口令长度不应少于十位；b) 应采用组成复杂、不易猜测的口令，一般应是大小写英文字母、数字和特殊字符中两者以上的组合；c) 应定期更换口令，更换周期不得长于一周；d) 存储口令的文件应采取密码措施存储、传输，并保证其安全。	1、通过系统的安全策略管理中的帐号管理实现密码长度、复杂度、最短使用期限、最长使用期限的设置存储 2、系统提供 MD5 或 CRYPT 等单向加密算法对口令进行加密存储	
4	鉴别方式： a) 应使用满足口令设置要求的口令方式进行身份鉴别；b) 采用智能卡或 USB Key 与口令相结合的方式的身份鉴别时，应满足以下要求：1) 口令长度设置不少于四位；2) 应选择使用能保证认证信息存储和传输安全的智能卡或 USB Key。	系统提供以下身份鉴别方式： 1、用户名和密码 2、证书（智能卡或 USB Key） 3、用户名、密码和证书相结合	
5	重鉴别： 用户身份鉴别成功后，当其空闲操作的时间超过规定值（通常为 10min 以内）后，在该用户需要执行其它操作之前，应对该用户重新进行身份鉴别。	系统中间件提供系统的超时时间设置	
6	鉴别失败： 当用户身份鉴别尝试失败次数达到五次后，应禁止使用该程序或延长一定时间后再允	系统提供对用户鉴别失败尝试次数进行设置，能够根据 IP 地址锁定鉴别失败的用户	

序号	国家保密局标准要求	任务及技术实现	备注
	许尝试，同时形成审计事件并告警。		
二、访问控制			
7	访问控制策略：应对系统内涉密数据的访问采用强制访问控制策略。 涉密信息和重要信息的访问控制，主体应控制到单个用户，客体应控制到信息类别。	系统提供的基于的 IP 访问控制策略，并能够根据用户的角色类型提供数据级别的访问控制策略	
8	用户类别划分：应用系统应至少包括如下用户类别及角色划分：系统管理人员（系统管理员、安全保密管理员、安全审计员），系统用户（重要、一般等），并具有相应的权限授予、收回等控制功能。所配备的系统管理员、安全保密管理员和安全审计员三类安全保密管理人员，分别负责系统的运行、安全保密和安全审计工作。 系统管理员主要负责系统的日常运行维护工作； 安全保密管理员主要负责系统的日常安全保密管理工作，包括用户帐号管理（账户的建立、删除除外，由系统管理员负责）、权限设置以及系统所产生日志的审查分析；	系统根据分级保护的要求内嵌系统管理员、安全保密管理员和安全审计员的三员分离的管理模式	

序号	国家保密局标准要求	任务及技术实现	备注
	安全审计员主要负责对系统管理员、安全保密管理员的操作行为进行审计跟踪分析和监督检查，以及时发现违规行为，并定期向系统安全保密管理机构汇报相关情况。		
9	信息类别划分： 应按照重要程度及知悉范围划分信息类别，具体划分方法应参照应用系统功能及具体业务数据流程。	本项目可以依据应用系统功能及具体业务数据流程划分信息类别	
10	访问控制粒度： 应按照主体类别，客体类别进行涉密信息和重要信息的访问控制。	系统能够根据用户的角色类型提供入口级别、操作级别和数据级别的访问控制策略。	
三、安全审计			
11	审计范围： a) 应根据对应用系统的脆弱点进行分析，并根据系统运行性能和安全需求确定系统安全审计的范围；b) 确定的审计事件范围应对安全事件的事后追查提供足够的信息；c) 安全审计应与身份鉴别、访问控制、数据完整性等安全功能的设计紧密结合，并为下述可审计事件产生审计记录： 1) 审计功能的启动和关闭； 2) 系统内用户增加、删除； 3) 用户权限的更改；	系统提供的行为审核功能能够详细记录对应用、权限、数据、配置等任何修改或者删除操作	

序号	国家保密局标准要求	任务及技术实现	备注
	4) 系统管理员、系统安全员、审计员和一般操作员所实施的操作； 5) 其它与系统安全有关的事件或专门定义的可审计事件。		
12	审计记录内容：a) 审计记录应提供足够的信息，以确定发生的事件及其来源和结果； b) 审计记录应包括以下内容：事件发生的时间、地点、类型、主体和结果(成功或失败)。	系统提供的行为审核功能能够详细记录发生的事件及其来源和结果等内容	
13	审计记录存储：a) 应有充足的审计记录存储空间，防止由于存储空间溢出造成审计记录的丢失； b) 应具有存储空间的阈值设置功能，当存储空间将满时能及时进行告警；c) 审计存储空间将满时，采取措施覆盖最早存储的审计数据；d) 审计系统出现异常时，应保证存储的审计记录不被破坏；e) 审计记录应至少保存六个月。F) 审计存储空间将满时，应采取措施覆盖最早存储的审计数据或转存审计数据。	系统能够提供按数据总量、按时间的分表存储方式	需要甲方根据需求提供足够大的存储空间
14	审计记录查阅：a) 应定期(最长一个月)对审计记录进行审查或分析，调查可疑行为及违规操作，采取相应的措施，并及时报告	系统提供的行为审核功能能够对审核记录按照时间范围、主客体身份、行为类型等条件进行检索查询	

序号	国家保密局标准要求	任务及技术实现	备注
	b) 应提供对审计记录的统计、查询功能，包括按时间范围、主客体身份、行为类型等条件进行检索查询； c) 发现异常事件时，应及时通知相关人员； d) 应具有生成审计结果报告的能力。	系统提供的行为审核功能通过邮件、短信（用户需要自定义）等方式进行异常事件的通知	
15	审计记录的保护： 应对审计信息和审计系统进行授权访问控制，保证审计记录不被篡改、伪造和非授权删除。 对审计记录的操作应记录日志	系统提供的行为审核功能能够保证任何帐号不能对审核记录进行修改、删除等操作	
16	审计记录时间： 审计记录产生时的时间应由系统范围内唯一确定的时钟产生，以确保审计记录时间上的逻辑性，保证审计分析的正确性。	1、系统提供的行为审核功能将统一采用系统时间（可以参考时钟服务器提供的时间）记录审核记录发生的时间	
17	完整性校验： 应对系统内传输的涉密信息进行完整性检测，及时发现涉密信息被篡改、删除、插入等情况，并生成审计日志。	系统提供安全审计能过实现对涉密信息被篡改、删除、插入等情况的记录	

一.5.10 页面统一权限认证过滤器

此过滤器应包括以下功能：

1. 用户登录验证：除登录页外，所有页面访问均需要 Session，若没有 Session 则自动跳转到登录页，可以有一个例外文件配置。
2. 管理类页面权限验证：管理类页面存放的指定目录，对该目录下页面进行访问需要验证登陆人员拥有系统管理员权限。列表表单类的系统管理

页面可以单独配置权限。

3. 表单数据权限验证：表单页面访问业务数据时，要求该用户（部门、岗位）在 G_UFILES 表中存在对应记录。
4. 特别授权页面权限验证：特别授权页面指的是该类页面通过设置界面设定了只有特定权限的人员才可访问，此类授权信息应在启动时自动装载入内存缓存，在缓存中进行判定，是否有权限访问。
5. 启用 Referer Check 即来源检测。HTTP Referer 是 Request Headers 的一部分，当浏览器向 web 服务器发出请求的时候，一般会带上 Referer，告诉服务器用户从哪个站点链接过来的。服务器通过判断请求头中的 referer，也能避免 CSRF 的攻击。除了例外地址外（可配置），要求 HTTP Referer 全部都是本网站。

一.5.11 禁止 SQL 注入

所有数据访问必须使用参数模式。

一.5.12 禁止 XSS

1. 禁止将 get 或 post 传入的数据直接或简单处理后显示在页面上。
2. 用户能够控制的页面显示项必须通过 HtmlEncode、JavaScriptEncode、URLEncode 等方式处理后才能输出，防止浏览器直接运行脚本。

一.5.13 禁止 CSRF

启用 Referer Check 即来源检测。

一.5.14 操作审计日志

详见日志功能章节。

一.5.15 表单数据统一授权模式

表单数据统一授权模式指的是对系统中的表单数据进行访问时有一个统一的权限判断逻辑，其主要有 G_UFILES 表构成，数据字典参见附录。

一.5.15.1 G_UFILES 表更新模式

1. 通过创建文件获取权限

1. 当用户新建保存时，增加该用户的 G_UFILES 记录且 IS_SHARE 设置为 1 同时记录日志。
2. 当文件进行更改拥有者时，将该文件 G_UFILES. IS_OWNER 等于该用户的记录的 IS_OWNER 设置为 0，检查新拥有者用户是否在 G_UFILES 存在记录，若存在则设置 IS_OWNER=1，否则为新用户新建 G_UFILES 记录且设置 IS_OWNER=1。

2. 通过授权分享获取权限

1. 当进行授权查看操作（分享）时，若记录不存在则增加该用户的数据记录且 IS_SHARE 设置为 1 同时记录日志；否则仅将 IS_SHARE 设置为 1。
2. 当进行取消查看授权操作时，将 IS_SHARE 设置为 0，同时记录日志；检查 IS_MANAGER、IS_DISTRIB、IS_SHARE、IS_FLOW 若全部为 0，则删除该记录。

3. 通过分阅获取权限

1. 进行分阅时，若记录不存在则增加该用户的数据记录且 IS_DISTRIB 设置为 1，同时记录日志；否则仅将 IS_SHARE 设置为 1。

2. 取消分阅文件时，将 IS_DISTRIB 设置为 0，同时记录日志；检查 IS_MANAGER、IS_DISTRIB、IS_SHARE、IS_FLOW 若全部为 0，则删除该记录。

4. 通过流程获取权限

1. 发送流程时（包括增发、补发等）：若发送的下一环节收件人记录不存在则增加该用户的数据记录且 IS_FLOW 设置为 1，同时记录日志；否则仅将 IS_FLOW 设置为 1。
2. 错发回收时（包括退回、取消节点等）：根据退回环节 G_INBOX 的发送时角色+部门及实际操作人分别进行以下操作：判断 G_PNODES 中是否还存在人员（角色+部门）的记录，若不存在则将 IS_FLOW 设置为 0，同时记录日志；检查 IS_MANAGER、IS_DISTRIB、IS_SHARE、IS_FLOW 若全部为 0，则删除该记录。
3. 取消流程时：将所有该文件的 IS_FLOW 设置为 0；检查该文件所有记录的 IS_MANAGER、IS_DISTRIB、IS_SHARE、IS_FLOW 若全部为 0，则删除该记录。
4. 变更环节人员时：对原处理人进行取消操作；对新处理人进行发送操作。

一.5.16 附件加密

要求：设置统一开关，可以对附件文件自动进行加密和解密操作。推荐使用国密 SM4 算法。

提供历史数据加密工具，可以将数据进行批量加密或解密操作。

一.5.17 关键字段加密

一.5.17.1 加密算法

加密算法使用对称式加密算法，即国密 SM4 算法。

一.5.17.2 加密密钥设置

加密密钥为全局密钥，需要提供接口进行设置，一般会在启动时通过加密机的取得的加密串作为密钥。

一.5.17.3 敏感字段配置

敏感表字段通过配置文件进行配置，可自行定义文件名以及格式。

一.5.17.4 加密字段的存取

在配置中的表字段当使用 Parameter 方式进行添加时可自动进行加密。

对于 SELECT 的字段在将数据装载到 DATATABLE 时，可自动进行解密。

一.5.17.5 提供加密和解密函数 API

提供加解密函数 API，可直接调用进行加密或解密。包括 SM2、SM3、SM4 加密算法。

一.5.18 页面和 Cookie 中不出现用户及敏感信息

禁止在页面和 Cookie 中存放任何和用户相关的信息或其他敏感信息，防止 Cookie 劫持。

如果必须使用 Cookie，一定要用 Http Only 模式。

6. 安全管理制度

一.1 安全控制策略

一.1.1 超期强制修改密码

如果密码超期，用户登录后提醒，并强制修改密码后才可正常登入。根据系统配置项：SYS-SEC-0005 超期天数以及上次密码修改时间存放在个人信息配置表中）来确定是否需要修改密码。强制登录功能可以通过暂不创建用户 Session，强制弹出 Div 来修改密码，若用户取消则应退出到登录界面。

一.1.2 初次使用强制修改密码

用户初次登录后提醒，并强制修改密码后才可正常登入。根据最后一次登录时间：S-USER-0029，若为空则为初次登录，强制弹出 Div 来修改密码，若用户取消则应退出到登录界面。

一.1.3 使用强口令

口令不少于 10 字符；由大小写英文字母、数字、特殊字符中两者或两者以上组合构成。设置密码强度要求（SYS-SEC-0002）为强口令模式。

一.1.4 密码输入错误失败锁定

当用户身份鉴别尝试失败次数达到五次后，应禁止使用该程序或延长一定时间后再允许尝试。

根据密码输错锁定账户次数（SYS-SEC-0009）和密码输错锁定账户时间

(SYS-SEC-0010) 进行处理。

一.2 审计日志

审计日志字段包括操作人、操作大类、操作小类、操作内容、所在单位、所在部门、操作人 IP、操作人 mac 地址、操作时间、操作状态（成功或失败）。

一.2.1 普通人员日志

一.2.1.1 登录日志

1. 用户在输入密码时，如果输入错误，要记录日志信息，日志大类：登录日志；日志小类：登录失败；日志内容：[用户名]登录失败，密码错误。
2. 用户登录成功时，要记录日志信息，日志大类：登录日志；日志小类：登录成功；日志内容：[用户名]登录成功。
3. 用户登出时，要记录日志信息，日志大类：登录日志；日志小类：登出；日志内容：[用户名]登出。
4. 当用户身份鉴别尝试连续失败次数满足次数设置后需要记录日志，日志大类：登录日志；日志小类：多次尝试密码失败；日志内容：[用户名]多次尝试使用密码登录失败。

一.2.1.2 安全操作

1. 用户修改密码失败需要在日志中记录。日志大类：安全操作；日志小类：修改密码；日志内容：[用户名]修改密码失败。
2. 用户修改密码成功需要在日志中记录。日志大类：安全操作；日志小类：修改密码；日志内容：[用户名]修改密码成功。

一.2.1.3 业务操作

1. 菜单访问：通过菜单访问时记录日志，日志大类：业务操作；日志小类：菜单访问；日志内容：[用户名]访问[菜单名]。

2. 查询记录：通过综合查询或全文检索时记录日志，日志大类：业务操作；日志小类：查询记录；日志内容：[用户名]进行XX查询，查询条件为：XXXXX。
3. 查看文件：查看文件时记录日志，日志大类：业务操作；日志小类：查看文件；日志内容：[用户名]查看[模块名]-[文件名]-[文件ID]。
4. 正文查看：查看正文附件时记录日志，日志大类：业务操作；日志小类：查看正文；日志内容：[用户名]查看[正文文件名]-[正文ID]。
5. 打印文件：打印表单时记录日志，日志大类：业务操作；日志小类：打印文件；日志内容：[用户名]打印[模块名]-[文件名]-[文件ID]。
6. 创建文件：创建表单时记录日志，日志大类：业务操作；日志小类：创建文件；日志内容：[用户名]创建[模块名]-[文件名]-[文件ID]。
7. 修改文件：修改表单时记录日志，日志大类：业务操作；日志小类：修改文件；日志内容：[用户名]修改[模块名]-[文件名]-[文件ID]。
8. 删除文件：删除表单时记录日志，日志大类：业务操作；日志小类：删除文件；日志内容：[用户名]删除[模块名]-[文件名]-[文件ID]。
9. 上传正文附件：上传正文附件时记录日志，日志大类：业务操作；日志小类：上传正文附件；日志内容：[用户名]上传[模块名]-[文件名]-[正文ID]。
10. 修改正文附件：修改正文附件时记录日志，日志大类：业务操作；日志小类：修改正文附件；日志内容：[用户名]修改[模块名]-[文件名]-[正文ID]。
11. 删除正文附件：删除正文附件时记录日志，日志大类：业务操作；日志小类：删除正文附件；日志内容：[用户名]删除[模块名]-[文件名]-[正文ID]。
12. 发送：发送流程时记录日志，日志大类：业务操作；日志小类：发送；日志内容：[用户名]发送[模块名]-[文件名]-[文件ID]给XXX。
13. 退回：退回流程时记录日志，日志大类：业务操作；日志小类：退回；日志内容：[用户名]退回[模块名]-[文件名]-[文件ID]给XXX。
14. 回收：回收流程时记录日志，日志大类：业务操作；日志小类：回收；日志内容：[用户名]回收[模块名]-[文件名]-[文件ID]。
15. 取消流程：取消流程时记录日志，日志大类：业务操作；日志小类：取消流程；日志内容：[用户名]取消流程[模块名]-[文件名]-[文件ID]。

一.2.2 系统管理员日志

1. 新增（修改、删除）用户：新增（修改、删除）用户时记录日志，日志大类：用户管理；日志小类：新增用户（修改、删除）；日志内容：[用户名]新增（修改、删除）用户[用户名]-[用户 ID]（如果是修改用户需要描述修改的内容）。
2. 新增（修改、删除）部门：类似同上。
3. 授权：对任何对象进行授权或取消授权时记录日志，日志大类：授权管理；日志小类：授权（取消授权）；日志内容：[用户名]授权给[对象名]-[对象 ID][权限名]-[权限 ID]权限。（[用户名]取消了[对象名]-[对象 ID]的[权限名]-[权限 ID]权限）

一.2.3 安全保密员日志

1. 审批日志：进行操作审批时记录日志，日志大类：安全审批；
日志小类：批准（拒绝）；日志内容：[用户名]批准（拒绝）了[修改内容]的修改操作，[操作 ID]。

一.2.3.1 安全策略

1. 安全保密员可以设置用户密码超期天数 SYS-SEC-0005，该功能需要记录系统日志。日志大类：安全策略；日志小类：策略调整；日志内容：[用户名]修改密码超期天数为[天数]天。